

# SIMATS ENGINEERING

## ASSESSMENT TOOL 1

|                        |                     |
|------------------------|---------------------|
| <b>Name</b>            | <b>Shaik Reehan</b> |
| <b>Register Number</b> | <b>192565071</b>    |
| <b>Date</b>            |                     |
| <b>Time</b>            |                     |

**COURSE NAME:** Cybersecurity Incident Handling And Response

**COURSE CODE:** CSA60

---

### **COURSE OUTCOME COVERED**

**CO2:** *Analyze incident response preparation strategies through examination of team roles, policies, SOPs, risk management practices, along with compliance frameworks to ensure organizational readiness. (BL3, BL6)*

Activity Tool : Incident Response Team Planning and SOP Development (High)

Assessment Tool Weightage: 40%

---

### ***Code of Conduct:***

*I \_\_\_\_\_ shaik reehan \_\_\_\_\_ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*

*I understand that any violation of academic integrity rules will result in disciplinary action.*

***Signature of the student:***

***Shaik reehan***

## RUBRICS FOR CALCULATION:

| Criteria                                              | Weightage  | Level 4<br>(Exemplary)                                                                                                                         | Level 3<br>(Proficient)                                                      | Level 2<br>(Developing)                                                        | Level 1<br>(Beginning)                                          |
|-------------------------------------------------------|------------|------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------|--------------------------------------------------------------------------------|-----------------------------------------------------------------|
| <b>Incident Response Team Planning</b>                | <b>20%</b> | Clearly identifies all key Incident Response Team roles, responsibilities, reporting structure, and interdepartmental coordination.            | Identifies most roles and responsibilities with minor omissions.             | Identifies only some roles with limited understanding of responsibilities.     | Unable to identify appropriate team roles or responsibilities.  |
| <b>SOP Development and Incident Handling Process</b>  | <b>25%</b> | Develops a comprehensive, logical SOP covering detection, reporting, containment, eradication, recovery, documentation, and communication.     | SOP includes most required phases with minor omissions or sequencing errors. | SOP covers only basic steps with several missing components.                   | SOP is incomplete, incorrect, or lacks logical flow.            |
| <b>Security Policies, Awareness, and Governance</b>   | <b>20%</b> | Presents well-structured security policies, awareness program, and governance practices with clear justification.                              | Includes relevant policies and awareness activities with minor gaps.         | Provides limited policies or awareness measures with insufficient explanation. | Fails to identify appropriate policies or governance practices. |
| <b>Risk Assessment, BCP, and DRP</b>                  | <b>20%</b> | Accurately identifies critical assets, performs risk assessment, and clearly explains BCP and DRP strategies with appropriate recommendations. | Performs basic risk assessment and explains BCP/DRP with minor omissions.    | Partial risk assessment with limited understanding of BCP and DRP concepts.    | Unable to perform risk assessment or explain BCP/DRP.           |
| <b>Documentation, Communication, and Presentation</b> | <b>15%</b> | Documentation is well-organized, professionally presented, uses diagrams/tables effectively, and                                               | Documentation is organized with minor formatting or clarity issues.          | Documentation is partially organized with several                              | Documentation is poorly organized, incomplete, or               |

|  |  |                                |  |                         |                             |
|--|--|--------------------------------|--|-------------------------|-----------------------------|
|  |  | communicates<br>ideas clearly. |  | presentation<br>issues. | difficult to<br>understand. |
|--|--|--------------------------------|--|-------------------------|-----------------------------|

## 1. Incident Response Team (IRT) Planning

---

### Introduction

In today's digital world, cyberattacks such as ransomware, phishing, malware infections, insider threats, and data breaches have become common. Every organization must be prepared to respond quickly and effectively when a cybersecurity incident occurs. An Incident Response Team (IRT) is a specialized group of professionals responsible for identifying, investigating, containing, eliminating, and recovering from security incidents. The main objective of the IRT is to reduce financial losses, protect sensitive information, maintain business continuity, and restore normal operations as quickly as possible.

### Structure of the Incident Response Team

A medium-sized organization should establish a well-organized Incident Response Team consisting of members from both technical and non-technical departments. Each member performs specific responsibilities while working together throughout the incident lifecycle.

#### 1. Incident Response Manager (Team Leader)

The Incident Response Manager is the leader of the entire incident response process. This person is responsible for planning, coordinating, and supervising all response activities. Whenever a cyberattack occurs, the manager immediately activates the incident response plan and assigns responsibilities to each team member.

The manager also communicates with senior management, monitors the progress of the investigation, ensures that organizational policies are followed, and prepares the final incident report after the issue has been resolved. Good leadership and communication skills are essential for this role.

#### 2. Security Analysts

Security Analysts continuously monitor the organization's security infrastructure using tools such as Security Information and Event Management (SIEM), firewalls, antivirus software, and Intrusion Detection Systems (IDS). Their primary responsibility is to detect suspicious activities before they become major security incidents.

Once an alert is detected, they analyze system logs, network traffic, user activities, and security events to determine whether the alert is genuine or a false positive. They identify the source of the attack, evaluate its severity, and immediately inform the Incident Response Manager.

### 3. Incident Responders

Incident Responders are responsible for controlling and eliminating the attack. After identifying the affected systems, they isolate infected devices from the network to prevent the attack from spreading.

They remove malware, disable compromised user accounts, block malicious IP addresses, patch vulnerabilities, restore systems from backups, and ensure that normal business operations resume safely. They also document every action performed during the response process for future reference.

### 4. Digital Forensics Specialists

Digital Forensics Specialists investigate the incident to determine exactly how the attack occurred. They carefully collect digital evidence such as log files, memory dumps, hard disk images, emails, and network traffic without modifying the original data.

Their investigation helps identify the attacker's techniques, entry point, timeline, and affected resources. The collected evidence may also be required for legal investigations, insurance claims, or regulatory audits.

### 5. System and Network Administrators

System and Network Administrators provide technical support during the incident. They secure servers, routers, switches, databases, and workstations while implementing necessary configuration changes.

They install security updates, modify firewall rules, restore backup data, verify system integrity, and ensure that the organization's network becomes fully operational after recovery.

### 6. Legal and Compliance Team

Cybersecurity incidents often involve legal responsibilities. The Legal and Compliance Team ensures that the organization follows all applicable cybersecurity laws, privacy regulations, and contractual obligations.

They determine whether customers, government authorities, or regulatory agencies need to be informed about the breach. They also preserve legal evidence and provide legal advice before any public disclosure is made.

### 7. Human Resources (HR)

Human Resources become involved whenever an incident includes employees, such as insider threats, misuse of company resources, or violations of security policies.

HR conducts employee investigations, coordinates internal communication, organizes security awareness programs, and takes disciplinary actions when necessary. HR also supports employees during recovery by providing updated security guidelines.

#### 8. Public Relations (PR) Team

If the incident becomes public, the Public Relations team manages communication with customers, media organizations, and business partners.

They prepare official statements, answer public questions, protect the company's reputation, and ensure that only verified information is released. Proper communication helps maintain customer trust even during serious cyber incidents.

#### 9. Executive Management

Senior management provides strategic direction throughout the incident. They approve emergency budgets, allocate necessary resources, and make important business decisions.

Management also evaluates the financial and operational impact of the incident and ensures that long-term improvements are implemented after recovery.

#### Collaboration Between Departments

Effective incident response requires cooperation among multiple departments rather than relying only on the IT team.

##### IT Department

The IT department detects security incidents, isolates infected systems, removes malicious software, restores services, and strengthens technical security controls.

##### Human Resources

HR handles employee-related issues, supports internal investigations, organizes employee awareness programs, and manages disciplinary actions if policy violations occur.

##### Legal Department

The Legal team ensures compliance with cybersecurity laws, privacy regulations, evidence preservation requirements, and mandatory breach notifications.

##### Executive Management

Management provides leadership, approves critical decisions, allocates financial resources, communicates with stakeholders, and oversees business continuity planning.

##### Public Relations

The PR department communicates with customers, media, investors, and business partners while protecting the organization's public image.

## Benefits of a Well-Planned Incident Response Team

- Faster detection of cyberattacks.
- Reduced financial losses.
- Protection of sensitive organizational data.
- Improved coordination between departments.
- Faster system recovery.
- Better legal and regulatory compliance.
- Increased customer confidence and business reputation.

## Conclusion

A properly structured Incident Response Team enables organizations to respond quickly and efficiently to cybersecurity incidents. Clearly defined roles, effective communication, and cooperation among IT, HR, Legal, Management, and Public Relations help minimize damage, restore business operations, and improve future security preparedness.

## 2. Security Awareness and Governance

---

### Introduction

Employees are considered the first line of defense in cybersecurity because many cyberattacks begin by targeting users rather than technology. One of the most common attacks is phishing, where attackers trick employees into revealing passwords, downloading malware, or transferring sensitive information. Therefore, organizations must develop a comprehensive Security Awareness and Training Program supported by strong security governance and organizational policies.

### Security Awareness and Training Program

#### 1. Objectives of the Training Program

The main objective of the program is to educate employees about cybersecurity risks and encourage secure behavior while using organizational resources.

The objectives include:

- Increasing employee awareness of cyber threats.
- Reducing phishing and social engineering attacks.
- Promoting safe password management.
- Encouraging secure internet and email usage.
- Teaching employees how to identify suspicious activities.
- Improving incident reporting.
- Ensuring compliance with organizational security policies.
- Creating a strong security culture across the organization.

#### 2. Target Audience

Cybersecurity awareness should include every individual within the organization because attackers may target anyone.

##### Employees

Learn safe email usage, password management, and reporting procedures.

##### IT Staff

Receive advanced training on threat detection, vulnerability management, incident handling, and forensic investigation.



## **Managers and Executives**

Understand cybersecurity risks, business continuity planning, legal responsibilities, and decision-making during incidents.

## **HR and Finance Departments**

Receive specialized training because these departments frequently handle sensitive employee and financial information, making them attractive targets for attackers.

## **New Employees**

Complete cybersecurity orientation before receiving access to organizational systems.

## **3. Training Methods**

Organizations should use multiple learning methods to improve employee understanding and engagement.

### **Classroom Training**

Cybersecurity experts conduct face-to-face sessions explaining common threats, policies, and safe practices.

### **Online Learning Modules**

Employees complete self-paced training through e-learning platforms at their convenience.

### **Phishing Simulations**

The organization sends fake phishing emails to employees to evaluate their ability to recognize malicious messages.

### **Workshops**

Interactive discussions allow employees to solve real cybersecurity scenarios and practice incident reporting.

### **Videos and Demonstrations**

Short educational videos explain ransomware, malware, phishing, password security, and data protection.

### **Newsletters and Posters**

Regular awareness campaigns remind employees about emerging cyber threats and security best practices.

### **Quizzes and Assessments**

Online tests evaluate employee understanding after each training session.

## **4. Training Frequency**

Security awareness should be continuous rather than a one-time activity.

- New employee orientation before system access.
- Monthly awareness campaigns.
- Quarterly refresher training.
- Annual cybersecurity certification.
- Immediate training after major security incidents.
- Additional sessions whenever new cyber threats emerge.

## **5. Evaluation Techniques**

Organizations should continuously measure the effectiveness of their awareness program.

### **Phishing Simulation Results**

Measure how many employees correctly identify and report phishing emails.

### **Knowledge Assessments**

Evaluate employee understanding using quizzes, exams, and practical exercises.

### **Employee Feedback**

Collect suggestions to improve future training sessions.

### **Incident Reporting Statistics**

Monitor whether employees report suspicious activities more frequently after training.

### **Internal Security Audits**

Review compliance with organizational security policies and identify areas requiring improvement.

## **Organizational Security Policies**

Security policies provide official rules that employees must follow while using organizational systems and data.

Important policies include:

### **Password Policy**

Requires strong passwords, password complexity, regular password changes, and MultiFactor Authentication (MFA).

### **Acceptable Use Policy**

Defines proper usage of computers, email, internet services, and organizational resources.

### **Access Control Policy**

Ensures employees can only access information necessary for their job responsibilities.

### **Data Protection Policy**

Specifies procedures for storing, transmitting, encrypting, and disposing of confidential information.

### **Incident Reporting Policy**

Provides clear procedures for reporting suspicious emails, malware infections, lost devices, or security violations.

## **Role of Security Governance**

Security governance ensures that cybersecurity activities support organizational objectives while reducing risks.

Its responsibilities include:

### **Defining Security Responsibilities**

Clearly assigns cybersecurity duties to management, IT staff, employees, and third-party vendors.

### **Risk Management**

Identifies cyber risks, evaluates their impact, and implements appropriate security controls.

### **Regulatory Compliance**

Ensures compliance with laws, industry standards, and organizational policies.

### **Monitoring Security Performance**

Conducts regular security audits, vulnerability assessments, and policy reviews.

### **Resource Allocation**

Provides sufficient budget, skilled personnel, and security technologies for incident preparedness.

### **Continuous Improvement**

Uses lessons learned from previous incidents to strengthen future security policies and training programs.

## **Benefits of Security Awareness and Governance**

- Reduces phishing attacks.
- Improves employee cybersecurity knowledge.
- Encourages early reporting of suspicious activities.
- Protects sensitive organizational information.
- Improves compliance with regulations.
- Reduces financial losses caused by cyber incidents.
- Strengthens the organization's overall cybersecurity posture.

## **Conclusion**

A comprehensive Security Awareness and Training Program, supported by strong organizational security policies and effective governance, creates a security-conscious workforce capable of identifying and responding to cyber threats. Continuous education, regular assessments, and strong management support significantly improve incident preparedness and help organizations maintain a secure and resilient operating environment.